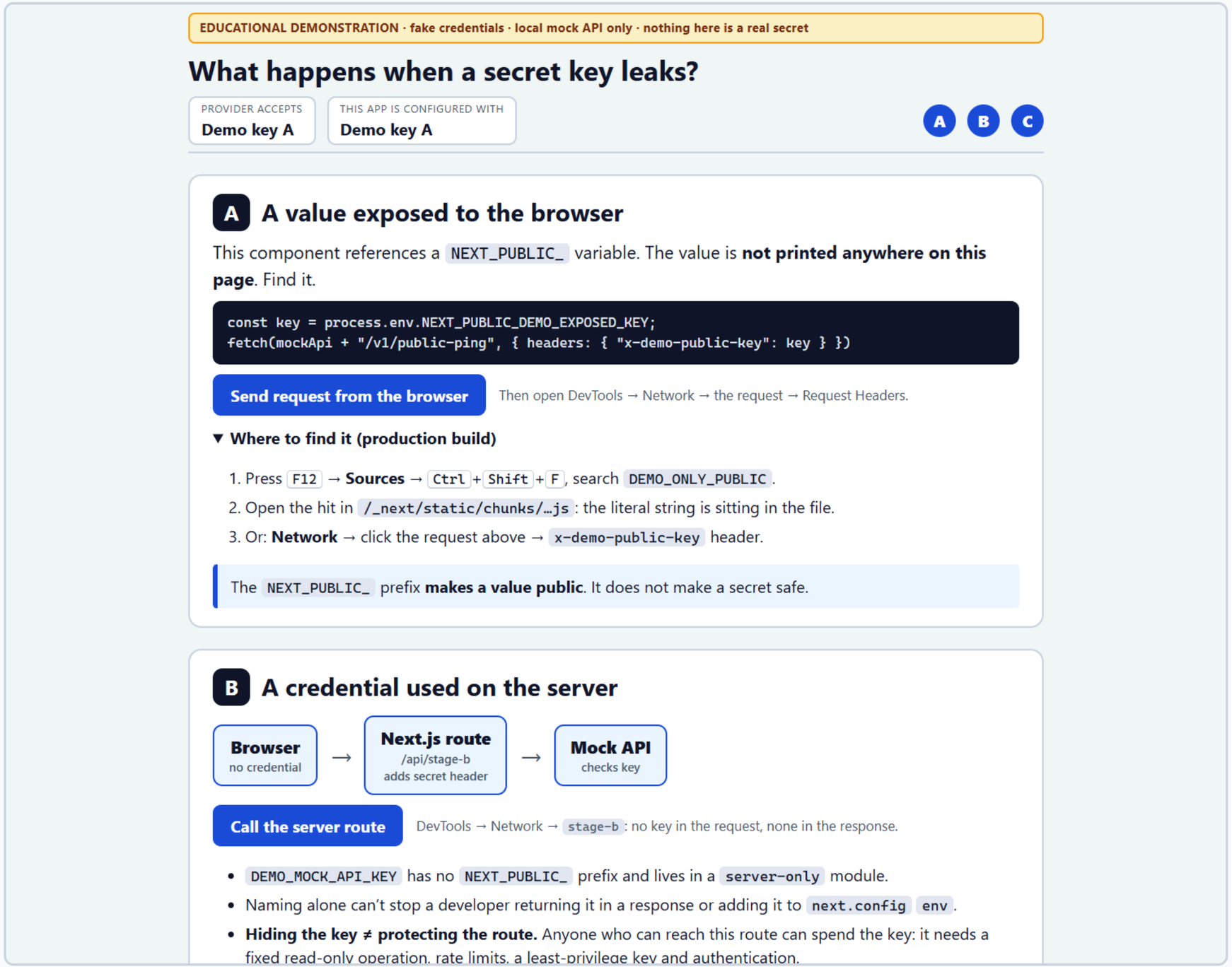
1/12 Start state

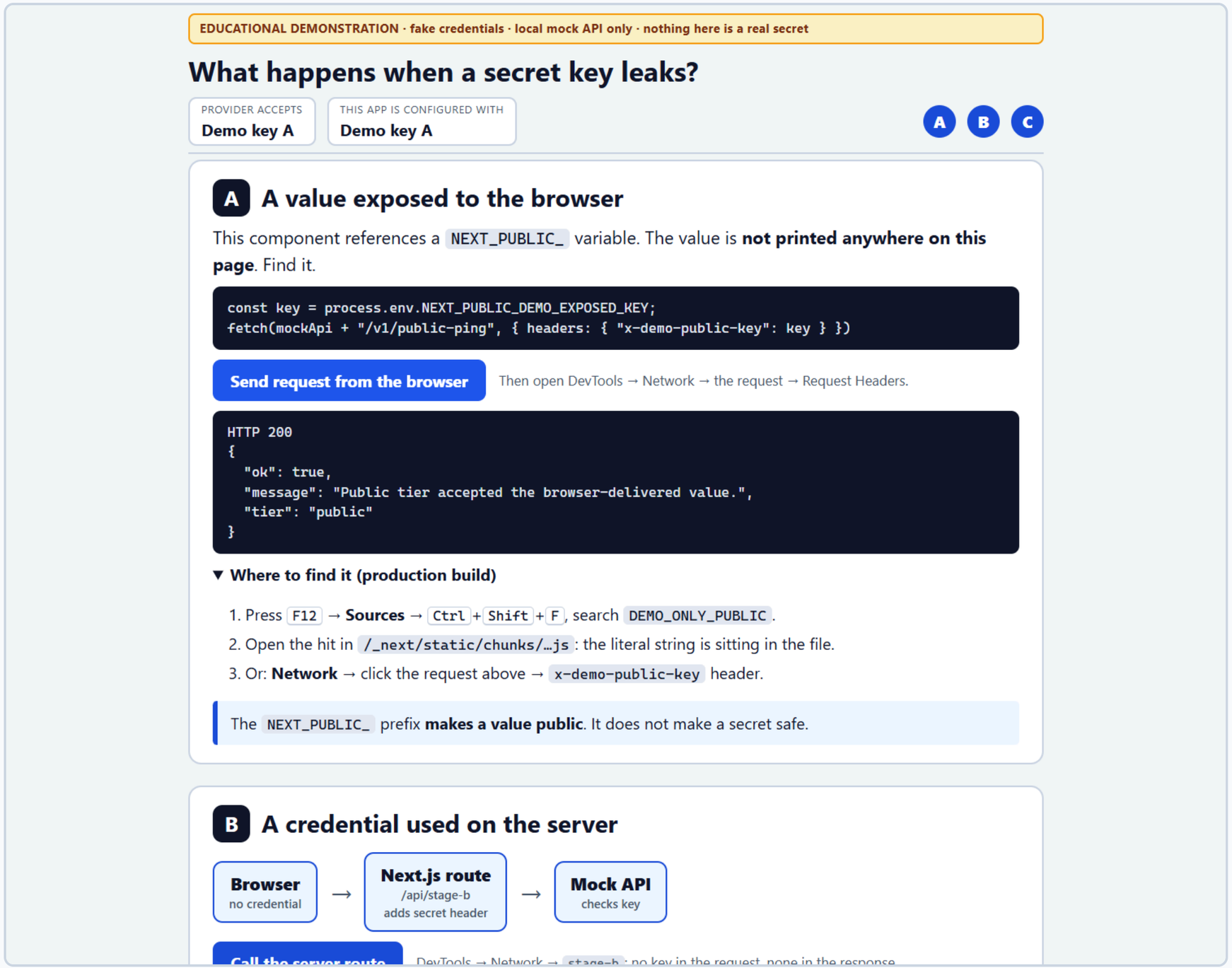
Banner marks this as an educational demonstration. Provider accepts Demo key A; the app is configured with Demo key A.



Say: Both services are local; keys are fake.

2/12 Stage A: browser sends a value

The component's NEXT_PUBLIC_ value is not printed on the page, but the browser sends it in a request header. The mock public tier accepts it (HTTP 200).



Say: Anything the browser sends, the user can read.

3/12 Stage A: the value is in the JavaScript file

Searching the production chunk for DEMO_ONLY_PUBLIC finds the literal string. Next.js inlined it at build time.

DevTools → Sources (search result): /_next/static/chunks/2m9ypg7iwvjtx.js

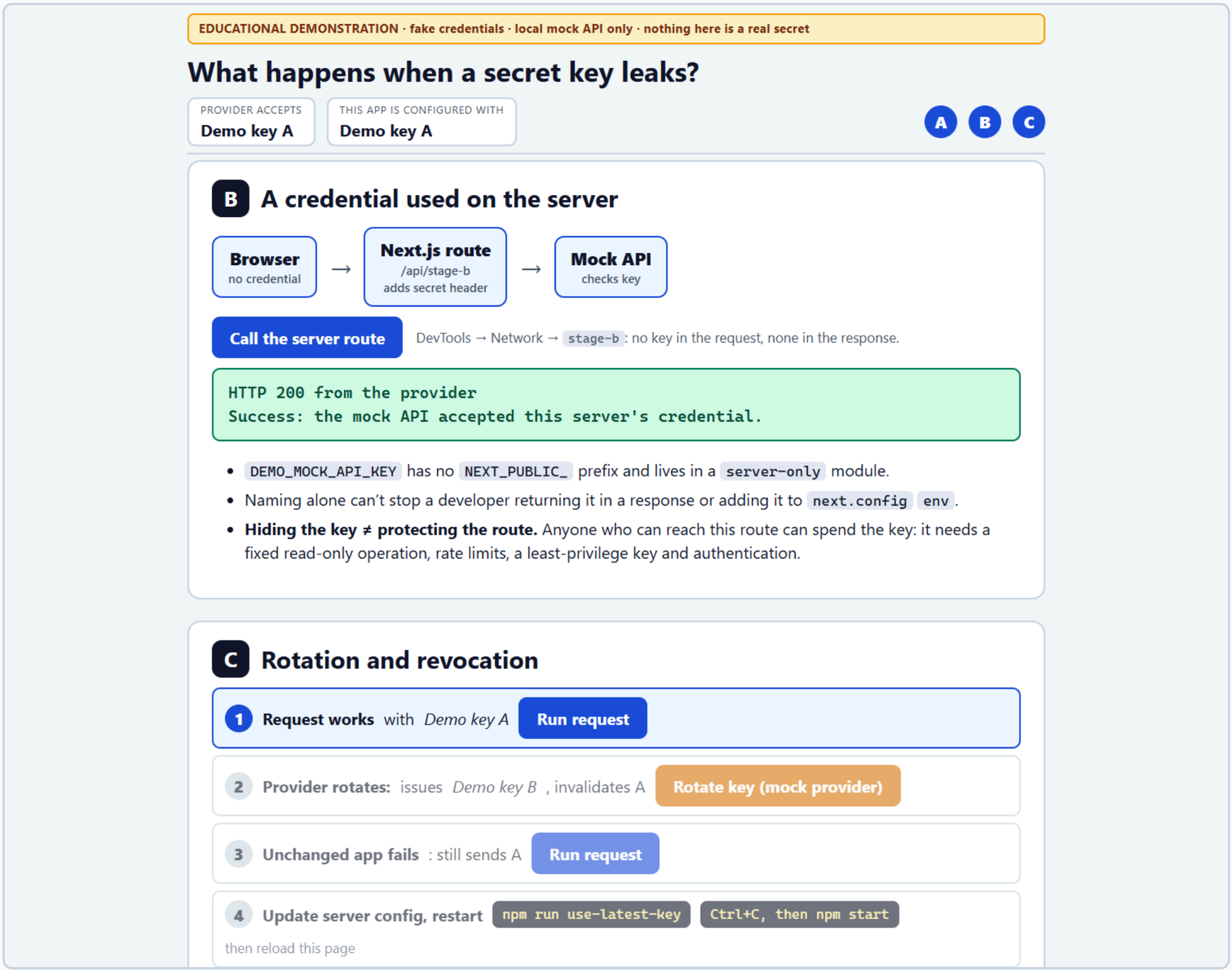
```
…tion l(){n(!0);try{let e=await fetch(`${t}/v1/public-ping`,{headers:{"x-demo-public-key":"DEMO_ONLY_PUBLIC_VALUE_NOT_A_REAL_CREDENTIAL"}});i(`HT
TP ${e.status} ${JSON.stringify(await e.json(),null,2)}`)}catch{i("Could not…
```

Excerpt of the real served file, highlight added. Search tip: Ctrl+Shift+F in DevTools, "DEMO_ONLY_PUBLIC".

Say: NEXT_PUBLIC_ makes a value public; it does not make a secret safe.

4/12 Stage B: server route succeeds

The browser called /api/stage-b. The server added the credential and the mock API accepted it. The browser only sees a harmless result.



Say: A server can use a credential without handing it to the browser.

5/12 Stage B: nothing secret on the wire to the browser

The request carries no credential header; the response has only labels and a message.

DevTools → Network → /api/stage-b

```
Request  POST /api/stage-b
  sec-ch-ua-platform: "Windows"
  referer: http://127.0.0.1:3000/
  user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/15
4.0.0.0 Safari/537.36
  sec-ch-ua: "Chromium";v="154", "Google Chrome";v="154", "Not A(Brand";v="99"
  sec-ch-ua-mobile: ?0
  accept: */*
  accept-encoding: gzip, deflate, br, zstd
  accept-language: en-US,en;q=0.9
  connection: keep-alive
  content-length: 0
  host: 127.0.0.1:3000
  origin: http://127.0.0.1:3000
  sec-fetch-dest: empty
  sec-fetch-mode: cors
  sec-fetch-site: same-origin
  (no credential header: the browser has none)

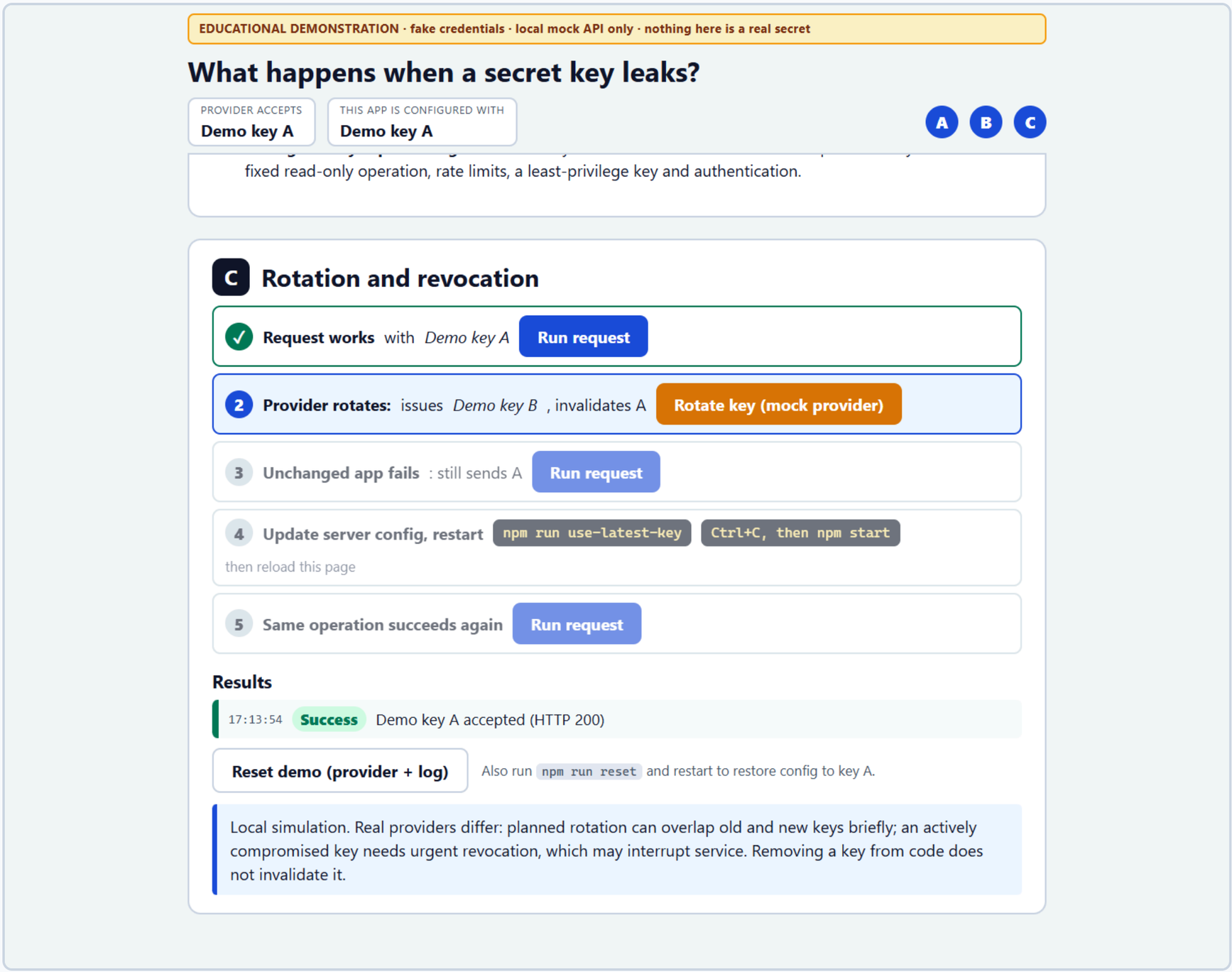
Response 200
{
  "configuredKeyLabel": "Demo key A",
  "ok": true,
  "upstreamStatus": 200,
  "providerKeyLabel": "Demo key A",
  "message": "Success: the mock API accepted this server's credential."
}
```

Captured from the browser's network events (same data DevTools → Network shows).

Say: Naming alone cannot stop a developer returning a secret; hiding the key does not protect the route (limits, least privilege, authentication).

6/12 Stage C 1: request works with Demo key A

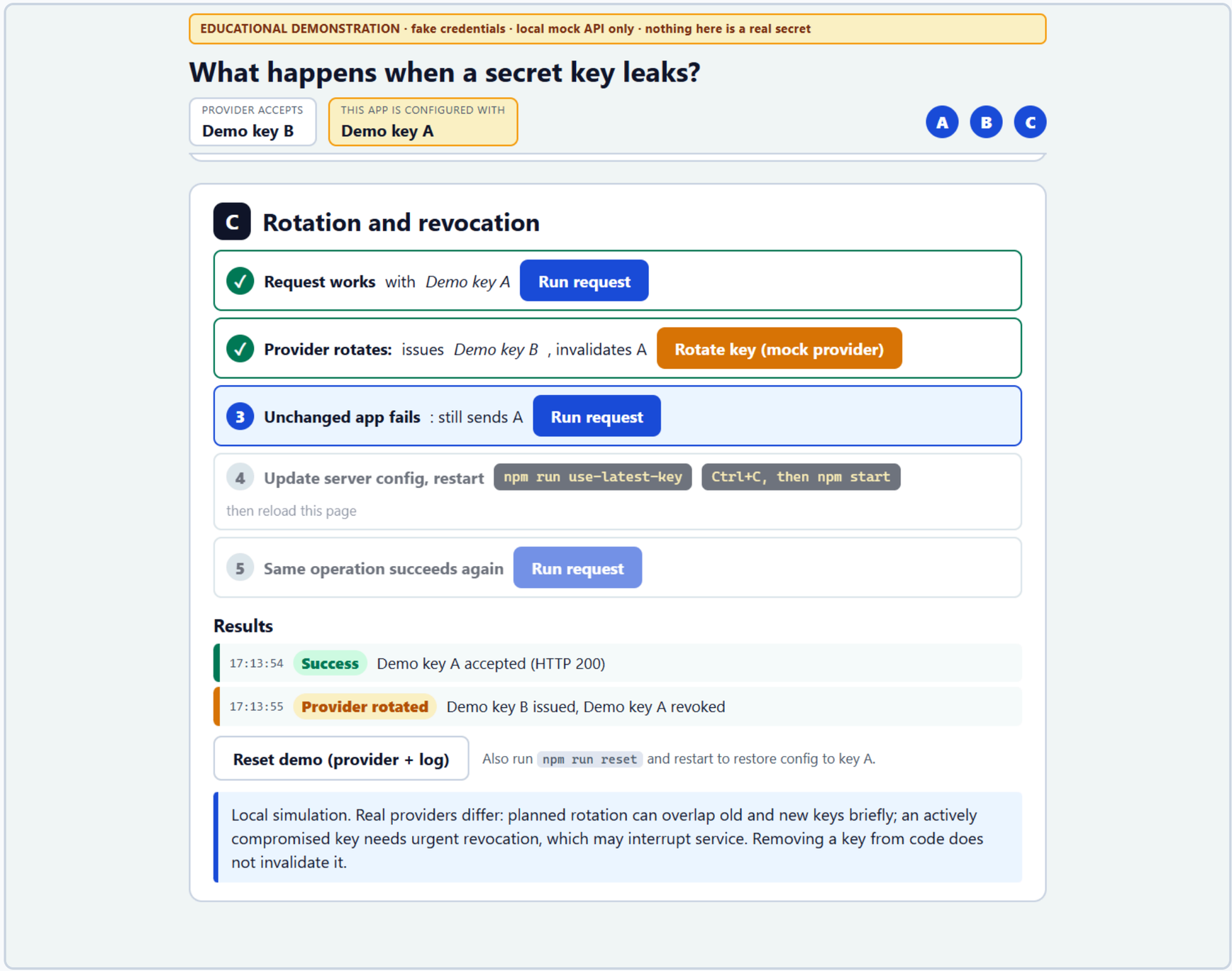
First entry in the results list: Success.



Say: Baseline.

7/12 Stage C 2: provider rotates

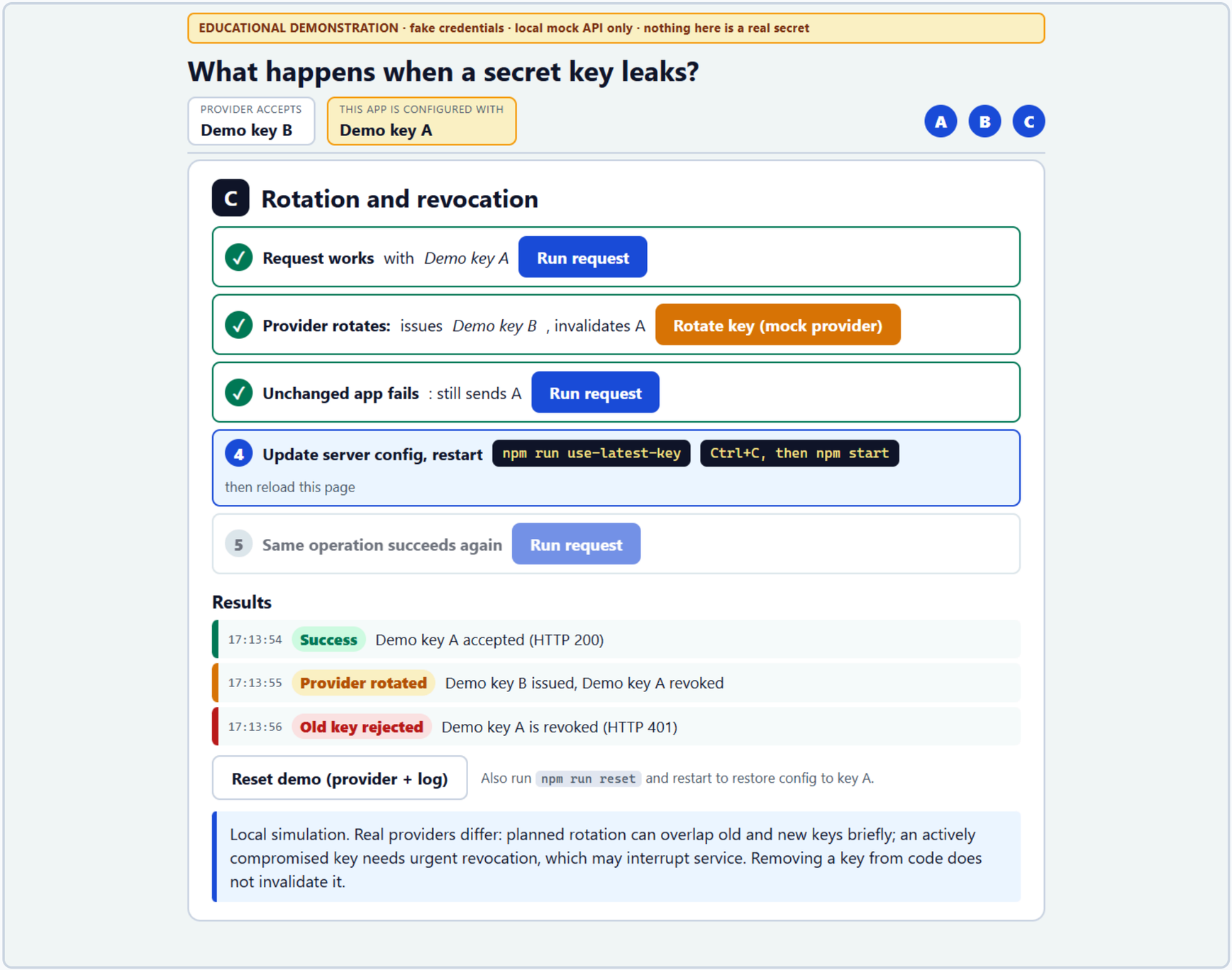
The provider issues Demo key B and revokes Demo key A. The status strip now shows a mismatch: provider accepts B, app still has A.



Say: Rotation changes what the provider accepts first.

8/12 Stage C 3: unchanged app is rejected

Same app, same code: HTTP 401, old key rejected.



Say: Removing a key from code does not invalidate it; only the provider can.

9/12 Stage C 4: update configuration and restart

npm run use-latest-key writes Demo key B into .env.local; the server is restarted so it re-reads its environment.

Terminal

```
> npm run use-latest-key
Updated .env.local: DEMO_MOCK_API_KEY is now Demo key B.
Restart the app so it re-reads its environment: Ctrl+C, then npm start. Then reload the page.

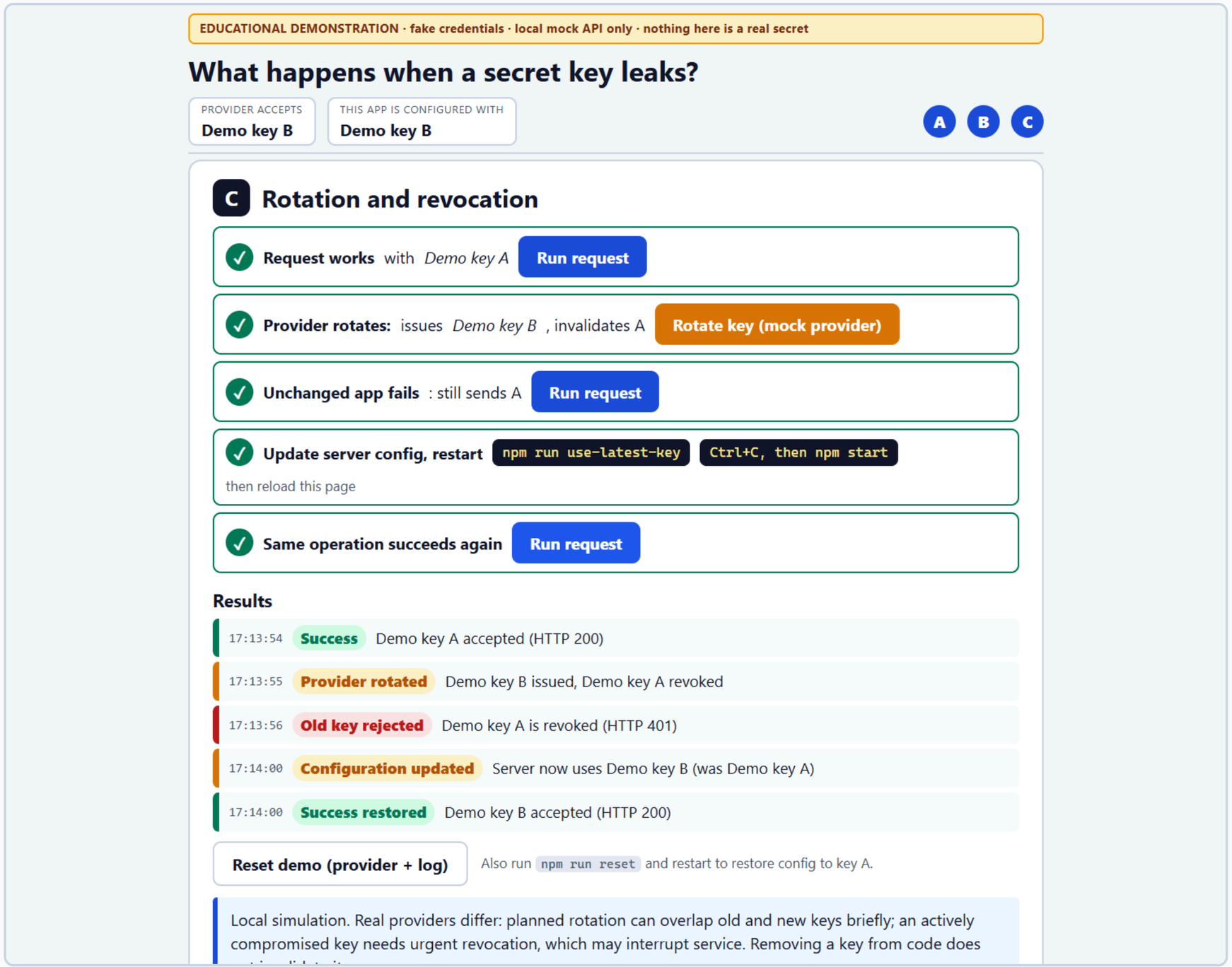
> (Ctrl+C)   > npm start
ready in 1.1s on http://127.0.0.1:3000
```

Captured output of the real command.

Say: Rotation must update both the provider and the application's configuration.

10/12 Stage C 5: success restored

After reload the status strip reads Demo key B. Results: Configuration updated, then Success restored.



Say: Planned rotation can overlap keys; a compromised key needs urgent revocation and may interrupt service.

11/12 Reset

npm run reset restores Demo key A at the provider and in .env.local; restart the app to repeat the demo.

Terminal

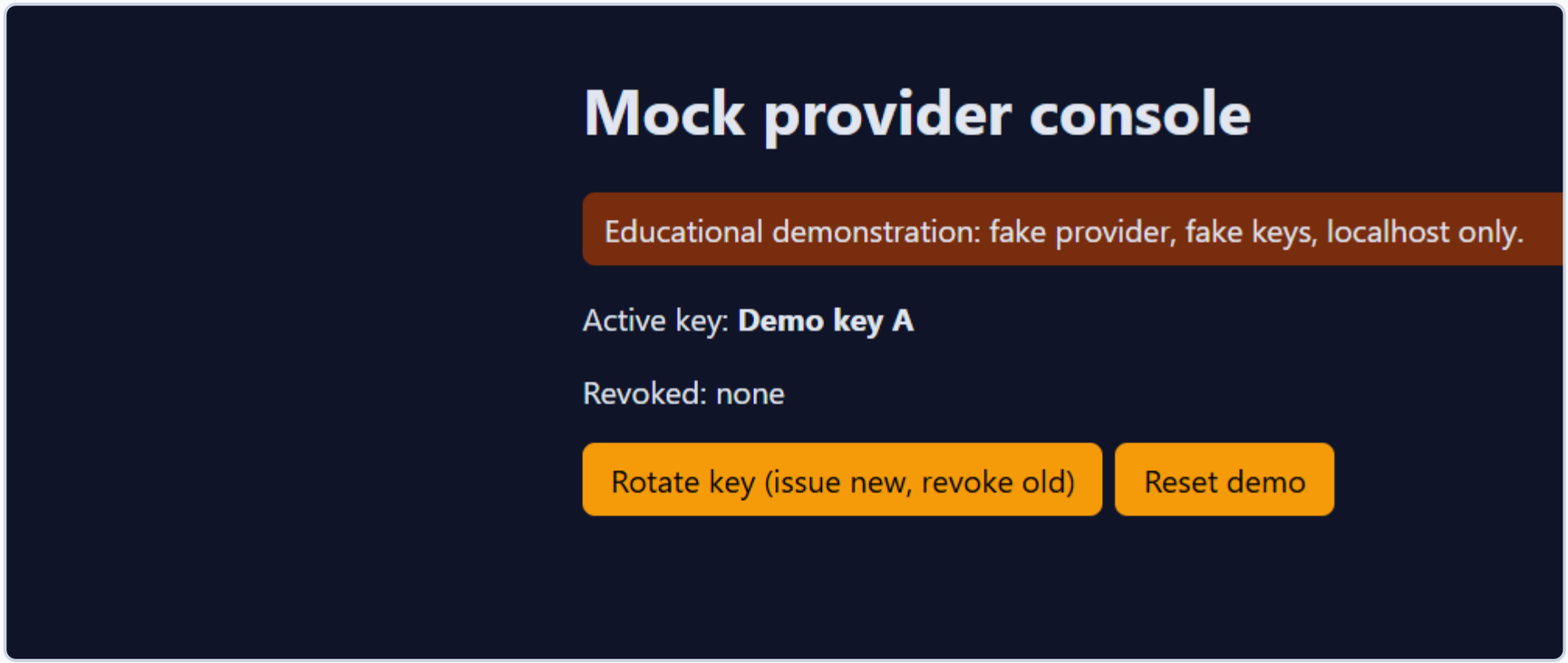
```
> npm run reset
Provider reset: Demo key A is active again.
Updated .env.local: DEMO_MOCK_API_KEY restored to Demo key A.
Restart the app (Ctrl+C, npm start) and reload the page. The browser log clears with the UI Reset button or a new
tab.
```

Captured output of the real command.

Say: The demo is repeatable.

12/12 Optional: provider console

http://127.0.0.1:4010/console shows the active and revoked keys and lets you rotate or reset; a new key is shown once, like a real dashboard.



Say: Manual alternative for the rotate and config steps.